COOKSHARE

Website chia sẻ công thức nấu ăn

> Báo cáo kỹ thuật và minh chứng kiểm thử
> React · Express · TypeScript · MySQL · Docker · Observability

Sinh viên: [Điền họ và tên]
Mã sinh viên: [Điền mã sinh viên]
Lớp / giảng viên: [Điền thông tin]

Repository: github.com/DTC245200747/CookShare
Ngày kiểm tra: 15/10/2026

Cần điền thông tin cá nhân trước khi nộp. Báo cáo phân biệt kết quả local và Docker đã xác minh trên Linux CI.

Từ repository trống đến ứng dụng chạy thật

Repository được clone vào workspace CookShare. Giai đoạn 1 đã có schema sáu bảng, API CRUD và JWT; yêu cầu mở rộng bổ sung giao diện, cộng đồng, quản trị và DevOps. Các phần cốt lõi đang hoạt động được giữ lại và mở rộng.

Mục tiêu sản phẩm

- Người dùng tìm được món ăn phù hợp, đọc nguyên liệu và từng bước thực hiện.
- Đăng công thức với ảnh thật, nguyên liệu và định lượng; quản lý công thức của mình.
- Tương tác qua yêu thích, đánh giá và bình luận; mọi dữ liệu nghiệp vụ lưu MySQL.
- Quản trị nội dung/tài khoản qua dashboard có số liệu thực.
- Cấu hình reverse proxy, metrics, dashboard và log tập trung.

Hạng mục ban đầu	Cách xử lý
API CRUD và phân quyền	Giữ lại transaction/validation, mở rộng tính năng
Frontend chưa chạy	Hoàn thiện React, build và phục vụ tại gốc web
Chỉ một công thức mẫu	Seed 21 công thức, chạy lại không nhân đôi
Chưa có monitoring	Thêm Prometheus/Grafana/Loki/Alloy và smoke script

Checklist ở `docs/FEATURE_CHECKLIST.md` chỉ dùng DONE cho phần đã kiểm thử thành công.

Các lớp và luồng xử lý

```
Trình duyệt React
        ↓ HTTP
Nginx :8080 — static frontend + security headers
        ↓ /api, /uploads
Express TypeScript :3000
        ↓ middleware → route/controller
        ↓ validation → repository/transaction
MySQL :3306 + volume dữ liệu

Prometheus ← API metrics + MySQL exporter + cAdvisor
Grafana ← Prometheus + Loki
Alloy ← Docker logs qua socket proxy → Loki
```

Phân chia mã nguồn

Frontend gồm pages, components, services và types. Backend chia routes/controllers/services/repositories/middleware/config. Migrations và seed tách khỏi mã HTTP. Docker frontend/backend có Dockerfile riêng.

Hai chế độ chạy

Development: Express phục vụ frontend/dist hoặc Vite proxy API/upload. Docker: Nginx phục vụ React, chuyển tiếp API và upload qua network nội bộ. MySQL không mở port ra host.

> Bản demo web đã chạy ở http://localhost:3000/. Docker stack đã chạy thành công trên Linux CI; Docker Desktop máy này chưa hoạt động.

Quan hệ, ràng buộc và tính toàn vẹn

Bảng	Vai trò
users, user_profiles, user_security	Tài khoản, hồ sơ, active và phiên token
categories, ingredients	Danh mục/nguồn nguyên liệu dùng chung
recipes	Tác giả, danh mục, mô tả, thời gian, khẩu phần
recipe_ingredients, recipe_steps	Định lượng và thứ tự thao tác
favorites, ratings	Khóa ghép user/recipe, chống bản tương tác trùng
comments	Nội dung, chủ bình luận và timestamps
recipe_moderation	Trạng thái published/hidden

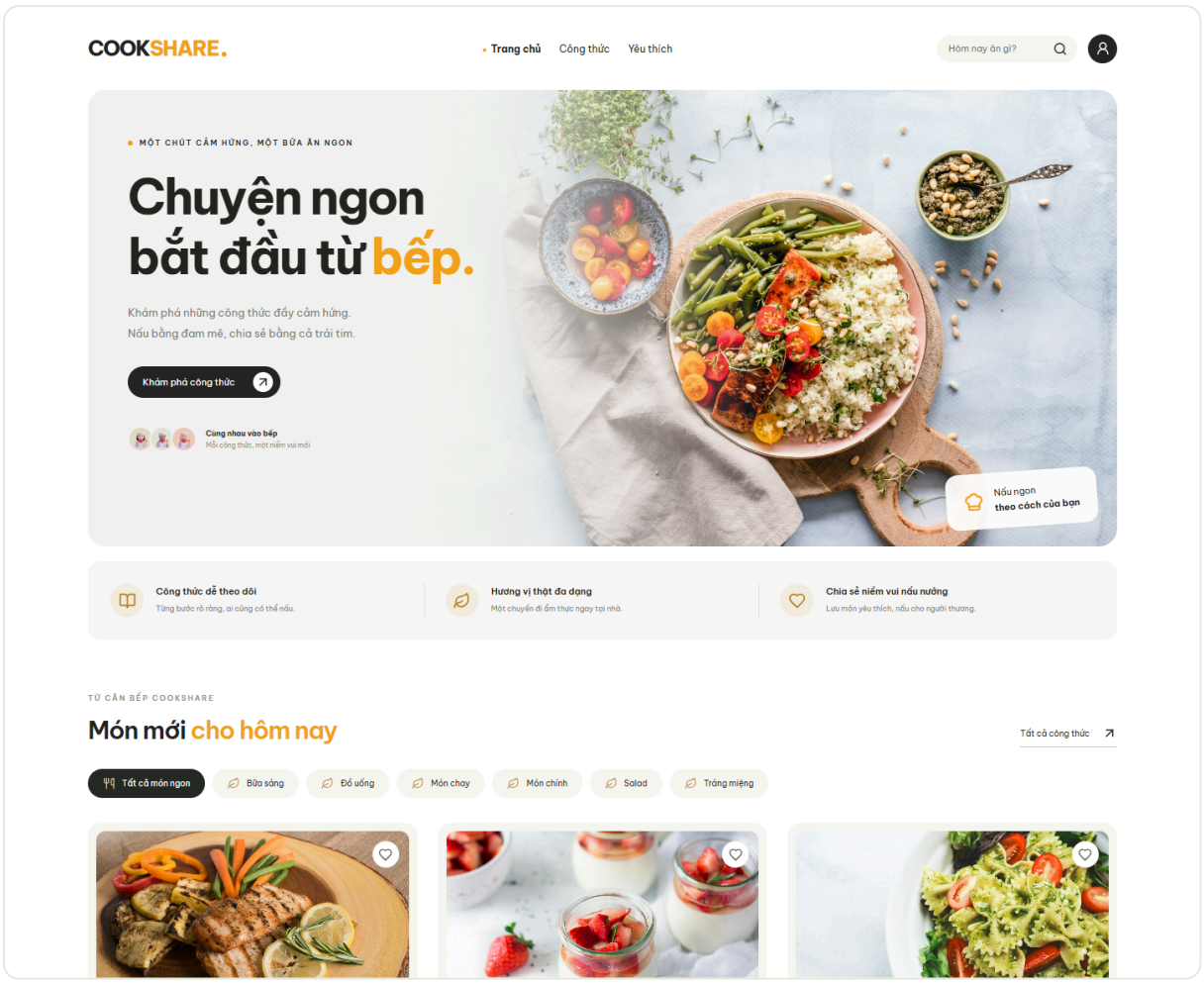
Các nguyên tắc

- Primary key, unique email/tên taxonomy; foreign keys ngăn dữ liệu mồ côi.
- Xóa recipe cascade children và tương tác; taxonomy đang dùng không xóa được.
- CHECK quantity dương, servings dương, score 1–5.
- Thay nguyên liệu/bước nấu trong cùng transaction. Lỗi FK rollback cả thay đổi tiêu đề.
- MySQL session và chuyển đổi ngày giờ dùng UTC.

Migrations và seed

Ledger schema_migrations và GET_LOCK tránh chạy đồng thời. DDL dùng IF NOT EXISTS vì MySQL tự commit DDL. Seed transaction, bcrypt và tên công thức/tác giả để kiểm tra tồn tại; có 21 công thức tiếng Việt và 6 danh mục.

Cảm hứng từ mẫu, nội dung từ MySQL



Ảnh chụp website chạy thật: banner, danh mục và thẻ công thức. Ảnh stock nằm trong source; nội dung công thức lấy từ API.

- Tông cam, trắng kem và xanh lá; card thống nhất, hiệu ứng hover nhẹ.
- Skeleton khi tải; trạng thái rỗng/lỗi và nút thử lại.
- Tìm kiếm tên/nguyên liệu, lọc danh mục, độ khó, thời gian và phân trang.
- Trang chi tiết có tác giả, đánh dấu nguyên liệu, steps và tương tác.

Kiểm thử trình duyệt tại 1440px, 820px và 390px kiểm tra ảnh tải được, không tràn ngang và các thao tác chính hoạt động.

Bảo vệ thao tác ở backend

Tài khoản và phiên

Register chỉ nhận name/email/password, luôn tạo member. Bcrypt cost 12; password 10 ký tự tối thiểu, tối đa 72 byte UTF-8. JWT HS256 có issuer/audience và hết hạn sau một giờ. Mỗi request đọc lại role, active và token_version từ MySQL.

Logout, đổi mật khẩu, thay quyền hoặc khóa user vô hiệu hóa phiên cũ. Đổi mật khẩu yêu cầu mật khẩu hiện tại; không có flow đặt lại mật khẩu qua email trong phạm vi hiện tại.

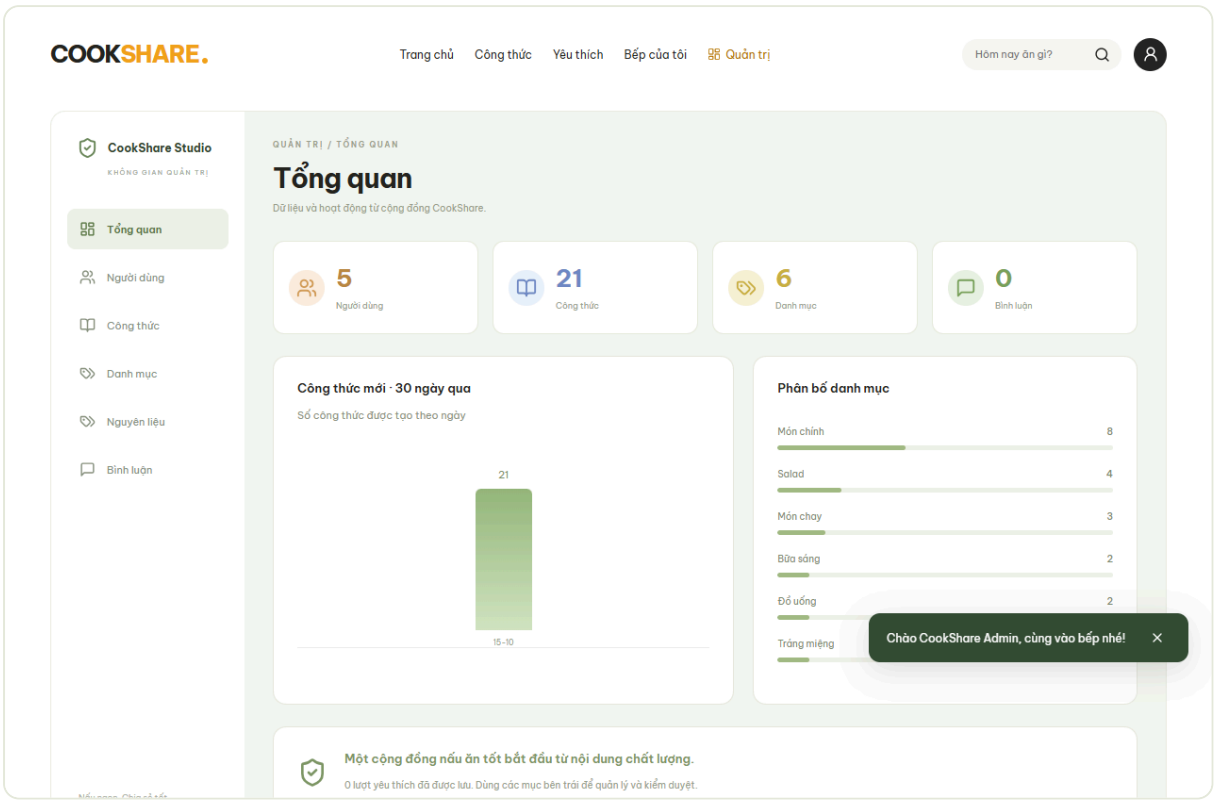
Chủ thể	Quyền
Public	Xem published recipe, taxonomy và bình luận
USER/member	Đăng recipe, sửa/xóa của mình, profile và tương tác
ADMIN	Quản lý user, taxonomy, mọi recipe/bình luận và moderation

Upload ảnh

- Chỉ tài khoản đăng nhập được upload một ảnh JPEG/PNG/WebP, tối đa 5 MB.
- Sharp xác minh nội dung thật, giới hạn pixel, resize tối đa 1600px và mã hóa lại WebP.
- File tên UUID, không dùng filename client làm đường dẫn, không phục vụ SVG/HTML.
- File lưu ổ đĩa/volume; URL lưu trong profile hoặc recipe MySQL.

> Tests đã gửi file giả mang MIME JPEG, SVG và file vượt dung lượng; tất cả được từ chối đúng status.

Nội dung và số liệu có thể kiểm chứng



Dashboard lấy counts và chuỗi hoạt động từ truy vấn MySQL; không dùng số liệu minh họa hardcode.

Cộng đồng

Favorites idempotent theo khóa user/recipe; ratings upsert một bản ghi mỗi user/recipe; bình luận có owner check khi sửa/xóa. Điểm trung bình và số lượt thích tính từ dữ liệu thực.

Dashboard

Sidebar, thống kê user/recipe/category/comment, biểu đồ 30 ngày và phân bố danh mục. Admin quản lý quyền/active, kiểm duyệt hiển thị, CRUD taxonomy và xóa bình luận. Danh sách có tìm kiếm, lọc và phân trang.

Hidden recipe không xuất hiện trong API public; owner/admin có thể xem để chỉnh sửa. Admin không thể tự khóa hoặc tự hạ quyền chính mình. Mọi API admin kiểm tra quyền ở backend.

Đóng gói ứng dụng và giới hạn quyền

- Dockerfile frontend build React rồi phục vụ bằng Nginx unprivileged.
- Dockerfile backend build TypeScript, prune dev dependencies, chạy user node.
- API filesystem read-only, uploads volume riêng. Network database/monitoring tách khỏi web.
- Tài khoản DB runtime chỉ CRUD trên schema; migration dùng tài khoản riêng.
- Helmet/CSP, Nginx headers, giới hạn payload/rate, CORS và validation.
- Nginx ghi đè X-Forwarded-For, API chỉ trust một hop trong topology Compose.
- MySQL không publish; công cụ quản trị bind loopback. Docker socket qua proxy chỉ đọc cho Alloy.

Chuỗi khởi động

MySQL healthy → migration thành công → API ready → Nginx. Seed chạy rõ ràng bằng lệnh riêng để không reset mật khẩu hoặc seed lại mỗi khi API restart.

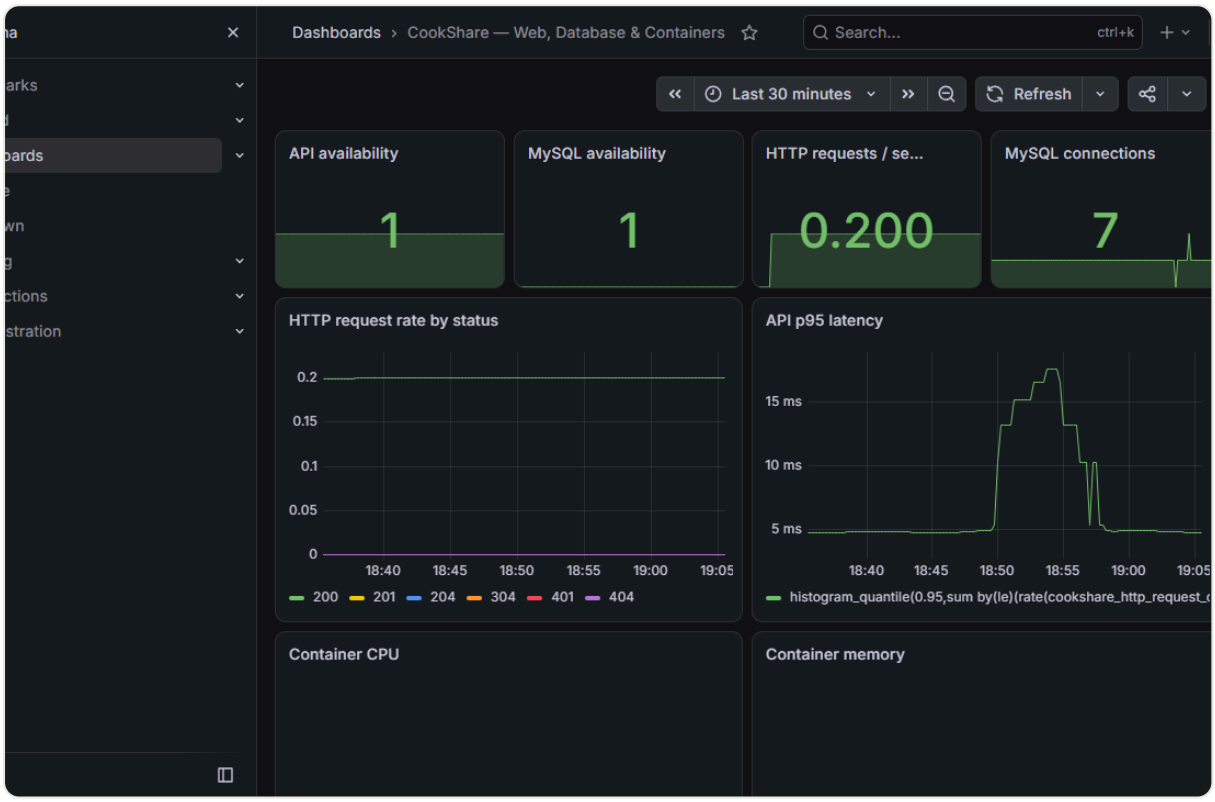
```
docker compose -f docker-compose.yml \
  -f docker-compose.monitoring.yml \
  --profile tools up -d --build
docker compose run --rm seed
node scripts/verify-stack.mjs
```

Vận hành

Backup MySQL và uploads; down không xóa volume. Public deployment cần TLS và thay secrets. Không có chứng nhận HTTPS hay triển khai public được tuyên bố trong báo cáo này.

Metrics, dashboard và LogQL

Prometheus scrape API HTTP/process metrics và MySQL exporter; cấu hình Docker bổ sung cAdvisor. Grafana provision Prometheus/Loki và dashboard 11 panel. Alloy thu log JSON của ứng dụng và đẩy vào Loki.



Truy vấn đã thực chạy

```
{job="cookshare",service="api"}
{job="cookshare",service="api"} | json | status >= 400
sum(count_over_time({job="cookshare",service="api"}[5m]))
```

> Đã xác minh bằng bản portable: Prometheus/API/MySQL exporter, Alloy đọc log file → Loki, Grafana datasource/dashboard. Docker discovery/log ingestion và samples container đã pass trên Linux CI; bản portable local không có cAdvisor nên các panel container ở ảnh có thể chưa có dữ liệu.

Kết quả thực chạy và giới hạn

Nhóm	Kết quả
Build TypeScript backend/React frontend	Pass
Integration HTTP + MySQL	26 tests pass; xem verification.md
Browser nghiệp vụ/responsive	3 kịch bản đầy đủ, screenshots thật
Grafana browser/datasources/dashboard	Kiểm tra riêng bằng Chrome và API
Migration/seed chạy lặp	Không nhân đôi, không reset mật khẩu cũ
Cấu hình Compose và monitoring	Kiểm tra cú pháp/config tools
Docker stack/cAdvisor/phpMyAdmin	Linux CI pass; chưa chạy Docker Desktop Windows

Những luồng đã được kiểm tra

Auth đúng/sai, owner/admin, transaction rollback, FK/cascade, profile, upload thật/giả/quá lớn, create-preview-edit-delete trên web, favorite/rating/comment CRUD, filters/pagination, dashboard/moderation và thu hồi token.

Tài liệu đi kèm

README.md; docs/api.md; docs/DEPLOYMENT.md; docs/verification.md; docs/FEATURE_CHECKLIST.md; screenshots; backend/frontend tests; hai workflow CI; scripts/verify-stack.mjs.

Thông tin sinh viên ở trang bìa cần được bổ sung. Hai workflow backend/browser và Docker stack đã SUCCESS trên GitHub. GUI login phpMyAdmin, Windows Docker, restore và tải lớn chưa được kiểm chứng. Xem QA_AUDIT.md và CI_EVIDENCE.md.